

Threat Model Using STRIDE

Sikaflow Company — Security Assessment

2. Attack Surface — Entry Points & Key Assets

The following table identifies the primary attack entry points and the assets most likely to be targeted in a breach:

#	Entry Point	Asset Involved	Why Attackers Target It
1	Login / Authentication Portal	AS-002 Authentication Server	Credential stuffing, brute force, session hijacking
2	Payment API Endpoint	AS-012 Payment Gateway API	Transaction fraud, man-in-the-middle attacks
3	Mobile App API	AS-004 Mobile API Server	API abuse, token replay attacks, insecure endpoints
4	Admin Portal / Dashboard	AS-021 IAM / AS-023 Admin Workstations	Privilege escalation, unauthorized admin access
5	VPN Remote Access	AS-018 VPN Gateway	Credential theft, unauthorized remote entry
6	Third-Party KYC API	AS-014 KYC Verification API	Spoofed responses bypassing identity checks
7	Mobile Money Integration	AS-013 Mobile Money API	Transaction interception, fund theft
8	Database Connection Layer	AS-005 Customer DB / AS-006 Transaction DB	SQL injection, unauthorized data access
9	SIEM / Logging System	AS-020 SIEM Platform	Log tampering to cover attacker tracks
10	Firewall Management Interface	AS-017 Firewall	Rule modification to allow malicious traffic

3. STRIDE Framework Overview

The STRIDE framework categorizes security threats as follows:

Letter	Threat Type	Definition	Security Property Violated
S	Spoofing	Impersonating a legitimate user or system to gain unauthorized access	Authentication
T	Tampering	Unauthorized modification of data in transit or at rest	Integrity
R	Repudiation	Denying an action was taken, often by erasing or altering logs	Non-repudiation
I	Information Disclosure	Exposing sensitive information to unauthorized parties	Confidentiality
D	Denial of Service	Flooding a system with requests to make it unavailable to legitimate users	Availability

E	Elevation of Privilege	Gaining higher access rights than intended by exploiting vulnerabilities	Authorization
----------	-------------------------------	--	---------------

4. S — Spoofing Threats

Spoofing occurs when an attacker impersonates a legitimate user, system, or service to gain unauthorized access. In a fintech environment like Sikaflow Company, spoofing poses a high risk as attackers can steal funds or access sensitive data by impersonating customers or internal staff.

ID	Affected Asset	Attack Scenario	Impact Level	Mitigation
S-01	AS-002 Authentication Server	Attacker uses credential stuffing (large lists of stolen username/password pairs) to gain access to user accounts via the login portal	CRITICAL	Implement Multi-Factor Authentication (MFA), rate limiting on login attempts, and CAPTCHA
S-02	AS-012 Payment Gateway API	Attacker forges API requests by stealing or replaying authentication tokens to initiate fraudulent transactions	CRITICAL	Use short-lived JWT tokens with signature verification, implement token binding and IP validation
S-03	AS-014 KYC Verification API	Attacker spoofs a KYC vendor response to pass identity verification with fake documents, creating fraudulent accounts	HIGH	Validate API responses with HMAC signatures; use mutual TLS between Sikaflow and KYC vendor
S-04	AS-021 IAM / AS-023 Admin Workstations	Attacker impersonates an IT administrator using phishing to capture credentials and access the IAM system	CRITICAL	Enforce privileged access workstations (PAW), hardware MFA (YubiKey), and admin session monitoring
S-05	AS-016 Notification Service API	Attacker spoofs the notification sender address to send fake transaction alerts, tricking users into revealing credentials (phishing)	HIGH	Implement DKIM/SPF/DMARC for email; digitally sign SMS and push notifications
S-06	AS-013 Mobile Money API	Attacker spoofs mobile money call-back responses to falsely confirm deposits or withdrawals	HIGH	Validate callback signatures, implement IP whitelisting for callback endpoints

5. T — Tampering Threats

Tampering involves the unauthorized modification of data. In a financial platform, tampered data can result in fraudulent transaction records, corrupted balances, or bypassed fraud detection rules — any of which can cause direct financial loss.

ID	Affected Asset	Attack Scenario	Impact Level	Mitigation
T-01	AS-006 Transaction Database	Attacker gains database access and modifies transaction amounts, dates, or statuses to	CRITICAL	Enable database audit logging; enforce write-once records for

		cover fraudulent fund transfers or alter account balances		completed transactions; use database checksums
T-02	AS-007 Fraud Detection Database	Attacker modifies blacklist rules or fraud thresholds in the fraud database, allowing fraudulent transactions to pass undetected	CRITICAL	Restrict direct database access; implement change-detection alerts; require 2-person approval for rule updates
T-03	AS-004 Mobile API Server	Attacker intercepts API traffic via a man-in-the-middle (MITM) attack and alters transaction request payloads before they reach the server	HIGH	Enforce TLS 1.3 with certificate pinning in mobile apps; validate all API inputs server-side
T-04	AS-008 Backup Database	Attacker encrypts or corrupts backup data (ransomware), making recovery impossible after an incident	HIGH	Maintain offline/immutable backups; test restoration regularly; use backup integrity verification hashes
T-05	AS-017 Firewall	Attacker with admin access modifies firewall rules to allow malicious traffic into the internal network	CRITICAL	Enforce change management with approval workflow; maintain configuration versioning; alert on unauthorized rule changes

6. R — Repudiation Threats

Repudiation threats arise when an attacker (or malicious insider) performs an action and is then able to deny it — typically by deleting or altering log files. In a regulated fintech environment, this violates audit requirements and can obstruct incident investigations.

ID	Affected Asset	Attack Scenario	Impact Level	Mitigation
R-01	AS-020 SIEM Platform	Attacker with elevated access deletes or alters system event logs, removing all traces of their activity from the security monitoring platform	CRITICAL	Use write-once, centralized log storage (e.g., AWS Cloud Trail with S3 lock); alerts on log deletion attempts
R-02	AS-006 Transaction Database	Malicious insider deletes transaction records after completing fraudulent transfers, denying the activity ever occurred	CRITICAL	Immutable transaction logs; hash-chaining of records; regulatory audit trail preservation
R-03	AS-002 Authentication Server	Attacker deletes authentication logs to hide unauthorized login attempts, preventing forensics from identifying the breach entry point	HIGH	Send auth logs to a separate, restricted SIEM in real time; alerting on any log gaps or deletions
R-04	Customer Support System	Customer disputes a transaction they actually authorized; without signed transaction records, the company cannot prove authorization	MEDIUM	Implement digital signatures on transaction approvals; store user consent and authorization confirmations

R-05	AS-019 Intrusion Detection System (IDS)	Attacker disables the IDS and deletes detection logs to avoid triggering alerts during an attack	HIGH	Implement IDS heartbeat monitoring; store IDS logs in separate immutable storage
-------------	---	--	-------------	--

7. I — Information Disclosure Threats

Information disclosure occurs when sensitive data is exposed to unauthorized parties. Sikaflow Company holds highly sensitive financial and personally identifiable information (PII), making this a high-priority threat category with significant legal and regulatory implications.

ID	Affected Asset	Attack Scenario	Impact Level	Mitigation
I-01	AS-005 Customer Database	SQL injection attack on the web portal extracts the entire customer table, exposing names, bank accounts, KYC data, and contact details of all users	CRITICAL	Use parameterized queries / ORM; conduct regular SQL injection testing; restrict DB user permissions to least privilege
I-02	AS-009 KYC / Identity Documents	Misconfigured cloud storage (S3 bucket set to public) exposes passport scans and national ID images of all verified users	CRITICAL	Audit all cloud storage permissions; enforce bucket policies; enable sensitive data detection tools
I-03	AS-001 Payment Server / AS-012 Payment Gateway API	Attacker sniffs unencrypted API traffic and extracts partial card numbers, account IDs, or authentication tokens from network packets	HIGH	Enforce TLS 1.3 for all communications; mask sensitive values in API responses and logs
I-04	AS-010 Analytics Database	Overly permissive database roles allow a junior analyst to query raw PII data that should be anonymized or masked	MEDIUM	Implement data masking and role-based access control (RBAC); anonymize data at query layer for non-privileged roles

8. D — Denial of Service Threats

Denial of Service (DoS) and Distributed Denial of Service (DDoS) attacks aim to make a system or service unavailable to legitimate users by overwhelming it with traffic or exploiting resource-intensive operations. For a payment platform, unavailability directly translates to financial loss and reputational damage.

ID	Affected Asset	Attack Scenario	Impact Level	Mitigation
D-01	AS-003 Web Application Server	Volumetric DDoS attack floods the public-facing web portal with millions of requests per second, making it inaccessible to users trying to make payments	CRITICAL	Deploy DDoS protection (AWS Shield, Cloudflare); enable auto-scaling; implement rate limiting and traffic scrubbing

D-02	AS-001 Payment Processing Server	Attacker sends thousands of concurrent payment requests in rapid succession, exhausting server threads and causing legitimate transactions to fail	CRITICAL	Implement request queuing and throttling; set concurrent connection limits; monitor server resource usage in real time
D-03	AS-004 Mobile API Server	Attacker exploits an unauthenticated API endpoint to generate repeated resource-intensive operations (e.g., bulk KYC lookups), degrading performance	HIGH	Require authentication on all API endpoints; implement API rate limiting per user and IP; use API gateway with WAF
D-04	AS-002 Authentication Server	Mass account lockout attack: attacker deliberately fails login for thousands of accounts to lock out legitimate users, disrupting access to the platform	HIGH	Implement progressive lockout (not binary); CAPTCHA after failed attempts; out-of-band unlock via verified email/SMS
D-05	AS-018 VPN Gateway	Attacker saturates VPN bandwidth with garbage traffic, denying remote staff and support teams access to internal systems during a critical incident	MEDIUM	Use redundant VPN endpoints across availability zones; implement QoS prioritization for critical traffic

9. E — Elevation of Privilege Threats

Elevation of privilege (EoP) attacks occur when an attacker (or malicious insider) exploits a vulnerability to gain higher access rights than they are authorized to have — for example, moving from a standard user account to a system administrator role.

ID	Affected Asset	Attack Scenario	Impact Level	Mitigation
E-01	AS-021 Identity & Access Management (IAM)	Attacker exploits a Kerb roasting vulnerability in Active Directory to extract service account hashes and crack them offline, gaining domain admin privileges	CRITICAL	Use Managed Service Accounts with random long passwords; enable Defender for Identity; audit privileged group membership
E-02	AS-001 Payment Processing Server	Attacker exploits an unpatched vulnerability in the payment application to escape the application sandbox and execute OS-level commands as root	CRITICAL	Apply security patches within 24-72 hours of release; use containers with least-privilege; conduct regular penetration testing
E-03	AS-015 Internal Micro services API	Attacker compromises a low-privilege micro service and exploits missing authorization checks to call privileged internal APIs (lateral movement)	HIGH	Implement Zero Trust architecture; enforce service-to-service authentication (mTLS); apply API-level authorization checks
E-04	AS-023 Admin Dashboard / IAM	Attacker exploits a broken access control flaw in the admin web portal to access functions reserved for super-admins (e.g., disabling fraud rules)	CRITICAL	Enforce server-side authorization on every admin action; implement role-based access control (RBAC); conduct regular access reviews

10. Threat Summary Matrix

The table below summarises all identified threats, their STRIDE classification, affected assets, and overall risk level:

Threat ID	STRIDE Category	Affected Asset	Risk Level
S-01	Spoofing	AS-002 Authentication Server	CRITICAL
S-02	Spoofing	AS-012 Payment Gateway API	CRITICAL
S-03	Spoofing	AS-014 KYC Verification API	HIGH
S-04	Spoofing	AS-021 IAM / AS-023 Admin Workstations	CRITICAL
S-05	Spoofing	AS-016 Notification Service API	HIGH
S-06	Spoofing	AS-013 Mobile Money API	HIGH
T-01	Tampering	AS-006 Transaction Database	CRITICAL
T-02	Tampering	AS-007 Fraud Detection Database	CRITICAL
T-03	Tampering	AS-004 Mobile API Server	HIGH
T-04	Tampering	AS-008 Backup Database	HIGH
T-05	Tampering	AS-017 Firewall	CRITICAL
R-01	Repudiation	AS-020 SIEM Platform	CRITICAL
R-02	Repudiation	AS-006 Transaction Database	CRITICAL
R-03	Repudiation	AS-002 Authentication Server	HIGH
R-04	Repudiation	Customer Support System	MEDIUM
R-05	Repudiation	AS-019 Intrusion Detection System (IDS)	HIGH
I-01	Information Disclosure	AS-005 Customer Database	CRITICAL
I-02	Information Disclosure	AS-009 KYC Documents	CRITICAL
I-03	Information Disclosure	AS-001 Payment Server / AS-012 API	HIGH
I-04	Information Disclosure	AS-010 Analytics Database	MEDIUM
D-01	Denial of Service	AS-003 Web Application Server	CRITICAL
D-02	Denial of Service	AS-001 Payment Processing Server	CRITICAL
D-03	Denial of Service	AS-004 Mobile API Server	HIGH
D-04	Denial of Service	AS-002 Authentication Server	HIGH
D-05	Denial of Service	AS-018 VPN Gateway	MEDIUM
E-01	Elevation of Privilege	AS-021 IAM	CRITICAL
E-02	Elevation of Privilege	AS-001 Payment Processing Server	CRITICAL
E-03	Elevation of Privilege	AS-015 Internal Microservices API	HIGH
E-04	Elevation of Privilege	AS-023 Admin Dashboard / IAM	CRITICAL

12. Key Recommendations

Based on the STRIDE analysis, the following top-priority security controls should be implemented for Sikaflow Company:

- Enforce Multi-Factor Authentication (MFA) across all user-facing and admin portals immediately
- Implement a Zero Trust Architecture — never assume trust, always verify, even for internal services
- Deploy a WAF (Web Application Firewall) and DDoS protection service in front of all public-facing assets
- Apply the Principle of Least Privilege to all system accounts, API credentials, and database roles
- Enable immutable, centralized logging with the SIEM and set alerts for any tampering or deletion of logs
- Conduct quarterly penetration testing and annual red team exercises targeting the identified entry points
- Establish a patch management policy ensuring critical vulnerabilities are remediated within 72 hours
- Implement database activity monitoring and restrict all direct database access to authorized DBAs only
- Regularly audit IAM roles, Active Directory group memberships, and API key permissions
- Train all staff in phishing awareness, as the majority of privilege escalation and spoofing attacks begin with a phishing email